

Controls and Compliance Checklist

Organization: Botium Toys (Fictional Company)
Audit Type: Internal Security Audit
Framework: NIST Cybersecurity Framework (NIST CSF)

Controls Assessment Checklist

Question: Does Botium Toys currently have this control in place?

Control	Status
Least Privilege	✗
Disaster recovery plans	✗
Password policies	✗
Separation of duties	✗
Firewall	✓
Intrusion detection system (IDS)	✗
Backups	✗
Antivirus software	✓
Manual monitoring, maintenance, and intervention for legacy systems	✗
Encryption	✗
Password management system	✗
Locks (offices, storefront, warehouse)	✓
Closed-circuit television (CCTV) surveillance	✓
Fire detection/prevention (fire alarm, sprinkler system, etc.)	✓

Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Best Practice	Status
Only authorized users have access to customers' credit card information	✗
Credit card information is stored, accepted, processed, and transmitted in a secure environment	✗
Data encryption procedures are implemented for cardholder data	✗
Secure password management policies are adopted	✗

General Data Protection Regulation (GDPR)

Best Practice	Status
E.U. customers' data is kept private and secured	✗

Plan exists to notify E.U. customers within 72 hours of a breach	✓
Data is properly classified and inventoried	✗
Privacy policies, procedures, and processes are enforced	✓

System and Organization Controls (SOC Type 1 / Type 2)

Best Practice	Status
User access policies are established	✗
Sensitive data (PII/SPII) is confidential and private	✗
Data integrity ensures data is complete, accurate, and validated	✓
Data is available to authorized individuals	✗

Recommendations to the IT Manager

- Implement least privilege and separation of duties to restrict access to sensitive data.
- Encrypt sensitive customer and payment data at rest and in transit.
- Establish regular backups and a documented disaster recovery plan.
- Deploy intrusion detection and continuous monitoring capabilities.
- Strengthen password policies and implement centralized password management with MFA.
- Develop a complete asset inventory with data classification.
- Formalize monitoring and maintenance schedules for legacy systems.

Portfolio Note

This audit was conducted for a fictional organization and is intended to demonstrate internal security auditing, risk assessment, and compliance evaluation skills.

Prepared by: Sambou Kamissoko

LinkedIn: <https://www.linkedin.com/in/sambouk/>